
IT Security Audit: Midwest Central Bank

*Cybersecurity Risk Assessment
& Compliance*



Assessment Overview



Scope: Evaluation of IT Infrastructure, cybersecurity posture, and regulatory compliance



Timeline: 4 weeks assessment period



Key Focus Area(s): Legacy systems, threat landscape, GLBA/PCI DSS compliance



Overall Findings: Critical vulnerabilities identified requiring immediate remediation



Midwest Central Bank's IT Infrastructure

- Core banking systems rely on legacy platforms (10+ years outdated)
- Customer-facing interfaces: Online banking, mobile app, and ATM network
- Payment processing: Credit/debit card interactions, ACH transfers
- Internal Systems: Employee workstations, email, CRM
- Data Storage: Customer financial records, transactional databases
- Network: Branch connectivity, headquarters, data centers

Our Approach



Framework: NIST Cybersecurity Framework



Compliance Standards: GLBA, PCI DSS v4.0



Threat Intelligence: FBI IC3, FS-ISAC, CISA alerts

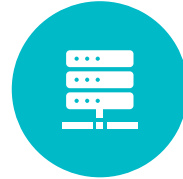


Risk Assessment: Likelihood vs. Impact Matrix



Industry Benchmarking: Comparing the financial sectors best practices

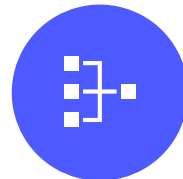
Key Findings: High-Risk Vulnerabilities



Outdated Systems: Windows Server 2008/2012 (no longer supported)



Weak Authentication: No multi-factor authentication (MFA) on critical systems



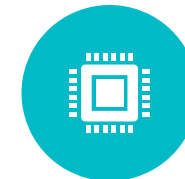
Poor Network Segmentation: Flat network architecture enables lateral movement



Unpatched Software: Critical security patches missing on 60%+ of systems



Insufficient Encryption: Customer data transmitted without end-to-end encryption



Limited Monitoring: No Security Information and Event Management (SIEM) solution

Current Threats to Financial Institutions

Ransomware: REvil, LockBit targeting financial sector (avg. \$1.85M loss)

Organized Cybercrime: Fin7 group specializing in financial data theft

Phishing/Social Engineering: 82% of breaches involve human element

Insider Threats: Privileged access abuse, data exfiltration

Supply Chain Attacks: Third-party vendor compromises

Risk Prioritization: Ransomware via Legacy Systems

Risk 1: Ransomware Exploiting Unpatched Legacy Core Systems

Core banking platforms are running on outdated operating systems without recent patches; legacy applications cannot support modern security protections.

Likelihood

High

Impact

Critical – Regular operations stop, ATM transactions stop, entire branch becomes inoperable

Mitigation Strategies

Immediate: Enable automatic updates on all IT systems

Short-Term: Begin Phased replacement of unsupported OS

Long-Term: Conduct annual reviews of security lifecycles

Risk Prioritization: Undetected Intrusion

Risk 1: Undetected intrusion due to lack of real-time monitoring

Current log reviewing systems are unknown, if no proper real-time tracking is in place, a threat actor could persist undetected in the system for extended periods of time

Likelihood

High

Impact

High – Data confidentiality breach and could be quietly exfiltrated, Internal fraud goes unnoticed, regulatory failure for "timely detection"

Mitigation Strategies

Immediate: Deploy Security Information and Event Management (SIEM) tool to log traffic and alert any abnormalities

Short-Term: Integrate SIEM into ATMs and CRM

Long-Term: Monthly SIEM tuning to reduce false positives

Risk Prioritization: Credential Compromise

Risk 1: Credential Theft caused by phishing or social engineering	Attackers can steal employee or customer credentials via phishing and social engineering. Lack of role-based access enables internal misuse and lateral spread if a breach were to occur.
Likelihood	High
Impact	Moderate – Customer accounts compromised, reputational damage

Mitigation Strategies

Immediate: Multi-factor authentication for all employees, and deploy role-based employee permissions across organization

Short-Term: Conduct employee training seminars to promote best practices

Long-Term: M Role-based access enforcement tied to job, audit credentials quarterly

Risk Prioritization: Threat Spread via Weak Incident Response Structure

Risk 1: Untested Incident Response Readiness	Current incident response plan is not rehearsed, Improper reporting timelines increase compliance penalties, Extended downtimes causes loss of revenue
Likelihood	Medium
Impact	High - Breach spreads before proper containment, Longer operation outages

Mitigation Strategies

Immediate: Identify primary incident response owners and escalation triggers

Short-Term: Conduct executive-level tabletop exercises

Long-Term: Formal IR “lessons learned” cycles after each incident or exercise, maintain updated escalation matrix and after-action reports

Risk Prioritization Heat Map

		SEVERITY →		
LIKELIHOOD ↓		Moderate 1	High 2	Critical 3
Low 1				
Medium 2	Vendor Breach - 2 -	Flat Network - 4 -	Weak IR Plan - 6 -	
High 3	Email Fraud (Credential Theft) - 3 -	Undetected Intrusion - 6 -	Ransomware (Legacy Exploit) - 9 -	



Regulatory Compliance Assessment: GLBA

GLBA Requirements:

Risk Assessment Program - Outdated (Last updated 2018)

Employee Training - Annual only, no phishing tests

Access Controls - Insufficient role-based access

Encryption Standards - Non-compliant

Incident Response Plan - Exists but untested

Regulatory Compliance Assessment : PCI DSS



FIREWALL
CONFIGURATION -
COMPLIANT



ENCRYPTION OF
CARDHOLDER DATA -
AT-REST ENCRYPTION
MISSING



ACCESS CONTROL
MEASURES - NO MFA
IMPLEMENTED



NETWORK
MONITORING - NO
SIEM SOLUTION



VULNERABILITY
MANAGEMENT -
IRREGULAR PATCHING

Immediate Actions (0-3 Months)

Implement Multi-Factor Authentication (MFA)

- Deploy on all privileged accounts and online banking
- Cost: ~\$50K | Risk Reduction: 99% of credential attacks

Emergency Patching Program

- Address critical vulnerabilities in Windows servers
- Cost: ~\$30K | Risk Reduction: 85% of exploitation attempts

Deploy SIEM Solution

- Real-time threat detection and monitoring
- Cost: ~\$120K annually | Enables rapid incident response

Enhanced Employee Security Training

- Monthly phishing simulations, security awareness
- Cost: ~\$25K | Risk Reduction: 70% of social engineering



Short Term Initiatives (3-12 Months)



Network Segmentation

- Isolate critical systems, implement zero-trust principles
- Cost: ~\$200K

System Modernization Roadmap

- Migrate from Server 2008/2012 to current supported versions
- Cost: ~\$500K-\$1M (phased approach)

Endpoint Detection & Response (EDR)

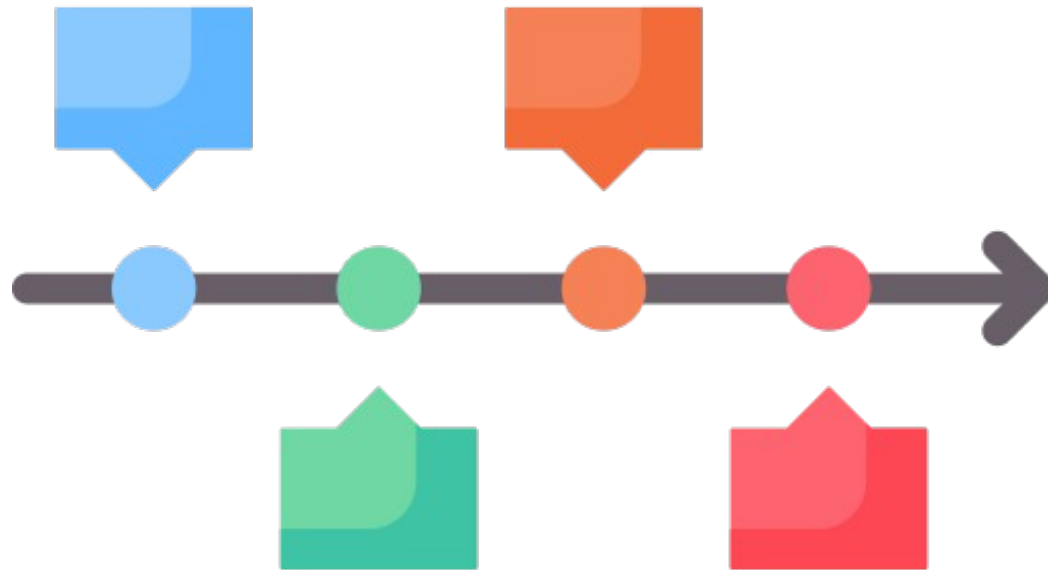
- Advanced threat protection on all workstations
- Cost: ~\$80K annually

Incident Response Plan & Testing

- Develop comprehensive IR plan, conduct tabletop exercises
- Cost: ~\$40K

Third-Party Risk Management Program

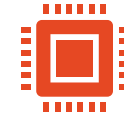
- Vendor security assessments and contracts review
- Cost: ~\$60K



Strategic Initiatives (12+ Months)



Cloud Migration Strategy: Evaluate hybrid cloud for enhanced security/scalability



Security Operations Center (SOC): Build or outsource 24/7 monitoring capability



Advanced Threat Intelligence: Subscribe to sector-specific threat feeds



Regular Penetration Testing: Quarterly external audits, annual red team exercises



Cybersecurity Insurance: Comprehensive coverage review and enhancement

Summary & Recommendations

Key Takeaways:

- Current cybersecurity posture presents **significant risk** to operations and compliance
- Immediate action required on MFA, patching, and monitoring
- Estimated total investment: **\$1.5-2M over 18 months**
- Expected outcome: **>80% risk reduction**, full regulatory compliance
- ROI: Average cost of financial sector breach is **\$5.9M** - prevention is cost-effective

Next Steps:

- Executive approval for Priority 1 initiatives
- Establish cybersecurity steering committee
- Quarterly progress reviews

